

Narrativa explicativa del enfoque GQM + PRAGMATIC

Cómo evitar que los indicadores AMPARO-ENS se conviertan en un sudoku burocrático

En el ecosistema ENS-INES-AMPARO, la tentación de acumular indicadores es fuerte: cada guía CCN-STIC, cada auditor y cada fabricante trae consigo su colección preferida. [web:32][web:33][web:21][web:39] El resultado puede ser un cuadro de mando exuberante y, sin embargo, poco útil.

El enfoque GQM + PRAGMATIC intenta vacunarnos contra ese derroche de cifras.

1. Del objetivo al dato, sin perderse en el camino

La idea de **Goal-Question-Metric (GQM)** es brutalmente sencilla:

1. Goal (Objetivo): qué queremos lograr y por qué.
2. Question (Pregunta): qué debemos preguntarnos para saber si vamos bien.
3. Metric (Métrica): qué dato concreto responde a la pregunta.

Aplicado a ENS:

- Objetivo: mejorar la adecuación ENS de la organización.
- Pregunta: ¿qué porcentaje de medidas ENS relevantes están implantadas?
- Métrica: % de medidas ENS implantadas, verificadas mediante la DA y evidencias documentadas.

Lo que este enfoque impide es el vicio de crear métricas porque “suena bien” o porque “Microsoft/NIST/ISO lo dice”, sin preguntarnos para qué queremos ese dato en el contexto concreto de ENS y del Informe INES. [web:30][web:32][web:33][web:21]

2. PRAGMATIC: nueve filtros contra la métrica inútil

Una vez tenemos la métrica, aparece la segunda línea de defensa: los criterios **PRAGMATIC**. Cada uno cuestiona un aspecto distinto:

- ¿Predice algo útil o solo describe el pasado?
- ¿Es relevante para nuestro objetivo o es ruido?
- ¿Nos dice qué hacer cuando se mueve?
- ¿Refleja la realidad o es “maquillable”?
- ¿Tiene sentido para quien decide (y para quien paga)?
- ¿Es lo suficientemente precisa para no confundir?
- ¿La obtenemos a tiempo para actuar?
- ¿No está sesgada por conflictos de interés?
- ¿Vale lo que cuesta medirla?

Si una métrica falla en demasiados de estos puntos, quizá deba vivir en un excel privado, pero no en el cuadro de mando que alimenta decisiones estratégicas ni en los informes que van al CCN o al órgano de gobierno. [web:32][web:33]

3. Por qué esto encaja tan bien con ENS, INES y AMPARO

ENS y sus guías STIC no inventaron GQM ni PRAGMATIC, pero los presupusieron de facto:

- El ENS marca los objetivos: garantizar la seguridad de la información en servicios públicos, con medidas proporcionadas a la categoría de los sistemas. [web:30][web:3]
- INES exige indicadores y datos coherentes a escala nacional. [web:21][web:39]
- AMPARO ordena la documentación, la DA y los planes de adecuación, de modo que los indicadores no floten en el vacío. [web:21][web:39]
- Las guías CCN-STIC-815/824 ponen énfasis en un “sistema de métricas” y en un Informe del Estado de Seguridad que no sea una mera colección de anécdotas. [web:32][web:33]

GQM ofrece la estructura conceptual para que cada métrica pueda explicarse con una frase que empiece por “queremos saber si...”. PRAGMATIC obliga a que, además, esa métrica no sea una curiosidad estadística sino una herramienta de gobierno.

4. Ejemplos sutilmente crueles

Consideremos dos métricas:

- “Número de páginas de la política de seguridad”
- “% de cuentas privilegiadas con MFA activo”

Ambas son fáciles de medir. Solo una supera razonablemente el test PRAGMATIC:

- La longitud de la política ni predice, ni es relevante, ni es accionable; puede ser incluso inversamente proporcional a la comprensión real.
- El porcentaje de MFA, en cambio, predice la probabilidad de compromiso, es central para Zero Trust y ofrece un plan de acción inmediato: llegar al 100 %. [web:11][web:15]

GQM diría que la segunda responde mejor a la pregunta “¿controlamos razonablemente el riesgo de compromiso de privilegios?”. PRAGMATIC confirma que, además, merece un lugar destacado en el cuadro de mando.

5. La tentación de medirlo todo

Se puede caer en dos extremos:

4. Medir casi nada, con el argumento de que “las métricas no capturan la complejidad”.
5. Medirlo todo, y ahogarse en un océano de datos que nadie lee.

El enfoque propuesto sugiere una tercera vía:

- Seleccionar un número limitado de objetivos claros (ENS, resiliencia, ROI).
- Para cada objetivo, definir unas pocas preguntas estratégicas.
- Para cada pregunta, elegir 1–3 métricas que superen razonablemente el filtro PRAGMATIC.
- Dejar las demás métricas en el backstage: útiles para análisis técnicos o auditorías específicas, pero no para saturar a la alta dirección.

6. Qué gana el CISO (y qué gana el Estado)

Para el CISO o responsable ENS, el beneficio es tangible:

- Puede explicar cada indicador con una historia clara: “medimos esto porque...”
- Dispone de un criterio argumentado para resistir la presión de añadir métricas “bonitas pero inútiles”.
- Conecta cada gráfico que presenta al Comité de Seguridad con un objetivo ENS o de ciberresiliencia verificable. [web:30][web:6][web:10]

Para el Estado, que mira el conjunto a través de INES, AMPARO y el Informe Nacional, el beneficio es sistémico:

- Mejores datos de entrada implican mejores diagnósticos a escala país. [web:21][web:33]
- Un vocabulario común de objetivos, preguntas y métricas facilita la comparación inter-territorial y sectorial.
- Se reduce el riesgo de que el ENS se perciba como una mera obligación documental.

7. Epílogo: menos fuegos artificiales, más brújulas

En resumen:

- GQM se asegura de que no existan métricas “huérfanas” de objetivo.
- PRAGMATIC se asegura de que no existan métricas “decorativas” en el cuadro de mando.
- Juntos, ayudan a que el ENS-INES-AMPARO deje de ser un sudoku burocrático para convertirse en lo que estaba llamado a ser: un sistema razonable de gobernanza de la ciberseguridad.

Lo cual, en los tiempos que corren, ya sería bastante milagro.